

INFORME TÉCNICO: ARQUITECTURA DE BASE DE DATOS Y SEGURIDAD TRANSACCIONAL EN E-COMMERCE

MÓDULO: CIB302-ONL-TALLER DE PLATAFORMAS WEB.

SEMANA: Semana 7.

Docente: Fernando Vera Araneda

Estudiante: Benjamín Ignacio Cisternas Huerta

Fecha: 29/09/2026

Enlace al repositorio de GitHub:

<https://github.com/GitChilenito/techstore-architecture>

Tabla de contenidos

Introducción	2
Desarrollo.....	3
Conclusión.....	4

Introducción

El presente informe documenta el diseño de la arquitectura de base de datos y la estrategia de seguridad para la plataforma e-commerce TechStore. Se analiza la elección del motor de base de datos adecuado, la gestión de transacciones seguras mediante consultas parametrizadas, y la definición de las instrucciones necesarias para garantizar la integridad y confidencialidad de la información.

Desarrollo

1. Selección Fundamentada de la Base de Datos (SQL vs. NoSQL)

Para la plataforma TechStore se ha seleccionado un motor de **Base de Datos Relacional (SQL)**, implementado mediante **PostgreSQL**.

Justificación Técnica:

- **Propiedades ACID:** Las transacciones financieras y de inventario requieren cumplimiento estricto de ACID (Atomicity, Consistency, Isolation, Durability). Esto asegura que un pago y el descuento de stock ocurran como un bloque indivisible.
- **Modelo Relacional Estricto:** Los datos del sistema (usuarios, productos, categorías, pedidos y detalle de venta) poseen dependencias estructurales claras mediante el uso de Claves Primarias (PK) y Claves Foráneas (FK).
- **Integridad Referencial:** Evita inconsistencias en la base de datos, como la creación de órdenes de compra asociadas a clientes o productos inexistentes.

2. Análisis de Riesgos y Medidas de Seguridad en Transacciones

Riesgos Identificados:

- **Inyección SQL (SQLi):** Ataque donde un usuario malintencionado introduce código SQL no autorizado en los campos de entrada (formularios de pago o búsqueda) para manipular la base de datos.

- **Condiciones de Carrera (Race Conditions):** Ocurre cuando dos usuarios intentan comprar la última unidad disponible de un producto de forma simultánea.
- **Intercepción de Datos en Tránsito:** Riesgo de captura de datos sensibles durante la comunicación entre el navegador del cliente y el servidor.

Medidas de Seguridad Propuestas:

1. **Consultas Parametrizadas (Prepared Statements):** Separación estricta entre la lógica de la consulta SQL y los datos ingresados por el usuario, neutralizando cualquier intento de inyección SQL en el backend.
2. **Validación y Sanitización en Backend:** Filtro estricto en el servidor para verificar tipos de datos, rangos válidos (precios y cantidades mayor a cero) y esquemas antes de procesar cualquier transacción.
3. **Control Transaccional (TCL):** Implementación de bloques de transacción (**BEGIN TRANSACTION**, **COMMIT**, **ROLLBACK**) para garantizar que si falla el cobro o la validación de stock, la operación se revierta completamente.
4. **Cifrado en Tránsito (HTTPS/TLS 1.3):** Uso obligatorio del protocolo cifrado HTTPS para proteger la integridad de los paquetes transferidos.

3. Clasificación de Instrucciones SQL para la Operación

Data Definition Language (DDL)

Utilizadas para definir y modificar la estructura de las tablas en la base de datos:

SQL

```
CREATE TABLE usuarios (  
  id_usuario SERIAL PRIMARY KEY,  
  nombre VARCHAR(100) NOT NULL,  
  correo VARCHAR(150) UNIQUE NOT NULL,
```

```
password_hash          VARCHAR(255)          NOT          NULL
);
```

```
CREATE          TABLE          productos          (
  id_producto      SERIAL          PRIMARY          KEY,
  nombre           VARCHAR(100)    NOT          NULL,
  precio           NUMERIC(10,2)   NOT          NULL,
  stock            INT             NOT          NULL    CHECK (stock >= 0)
);
```

Data Manipulation Language (DML)

Utilizadas para la consulta, inserción y actualización segura de datos:

SQL

```
-- Consulta parametrizada segura ($1 = id_producto)
SELECT id_producto, nombre, precio, stock FROM productos WHERE id_producto
= $1;
```

```
-- Actualización de inventario tras una compra
UPDATE productos SET stock = stock - $2 WHERE id_producto = $1;
```

Data Control Language (DCL)

Utilizadas para administrar los privilegios de acceso y aplicar el principio de menor privilegio:

SQL

```
GRANT SELECT, INSERT, UPDATE ON productos TO app_backend_user;  
REVOKE DELETE ON productos FROM app_backend_user;
```

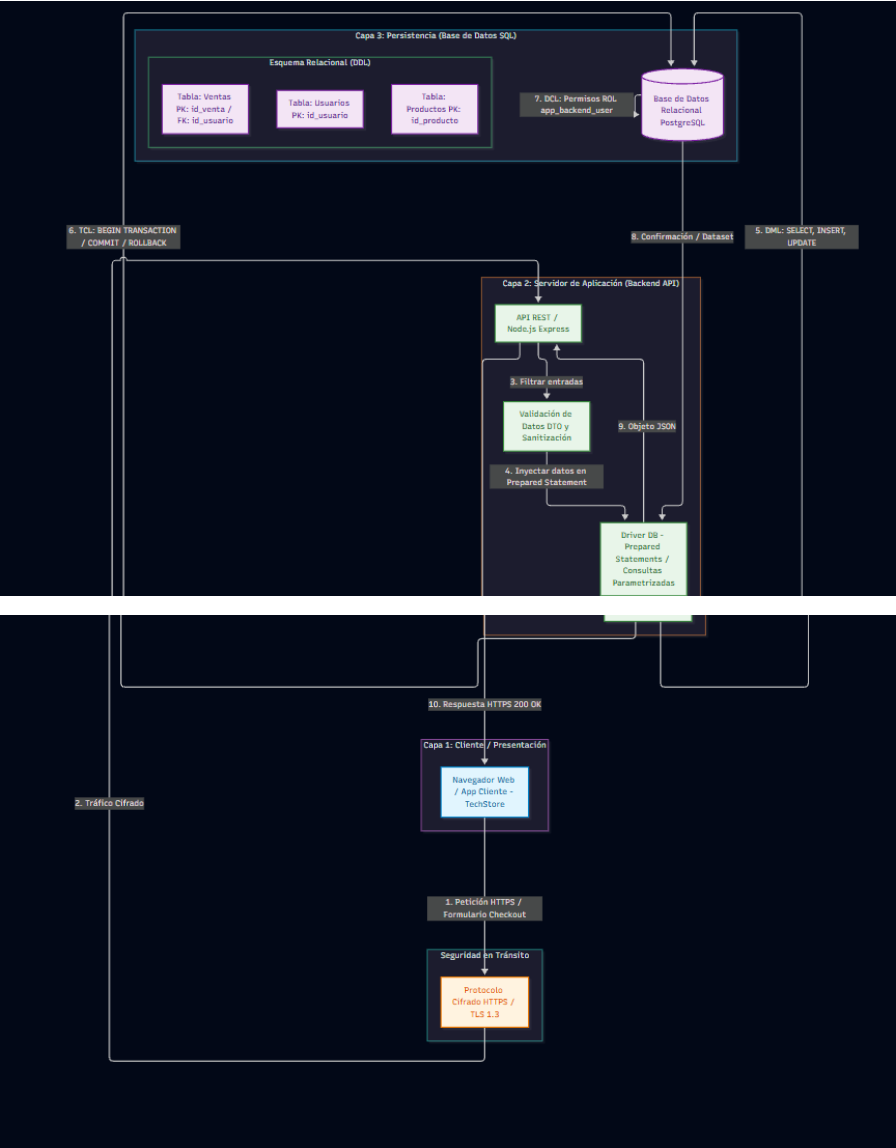
Transaction Control Language (TCL)

Garantizan la consistencia transaccional durante las compras:

SQL

```
BEGIN TRANSACTION;  
-- 1. Verificar y descontar stock  
-- 2. Registrar la venta  
COMMIT; -- O ROLLBACK en caso de error en el pago.
```

4. Diagrama De Arquitectura.



Conclusión

El diseño propuesto para TechStore garantiza un entorno confiable y seguro mediante el uso de un motor SQL con transacciones ACID, consultas parametrizadas contra inyecciones SQL y un control de accesos basado en privilegios mínimos.

Referencias

- **Auth0 by Okta.** (2024). Single-Page Application (SPA) Security Best Practices. Auth0 Docs. <https://auth0.com/docs/get-started/architecture-scenarios/spa-api>
- **Elmasri, R., & Navathe, S. B.** (2017). Fundamentos de sistemas de bases de datos (7.^a ed.). Pearson Education.
- **OWASP Foundation.** (2021). OWASP Top Ten: A03:2021 – Injection. OWASP Top 10. https://owasp.org/Top10/A03_2021-Injection/
- **PostgreSQL Global Development Group.** (2024). PostgreSQL 16 Documentation: Transactions and Concurrency Control. PostgreSQL Docs. <https://www.postgresql.org/docs/current/tutorial-transactions.html>
- **Silberschatz, A., Korth, H. F., & Sudarshan, S.** (2020). Database System Concepts (7th ed.). McGraw-Hill Education.